

	WEBDEPLOY Srl	43123, Via Puccini 15, Parma (PR)
	P.IVA/C.F.	IT02993340344
	Pec	legal@pec.webdeploy.it
	Tel.	+39 3398183373

// GAP-ANALYSIS · EDIZIONE 2026

> GAP-ANALYSIS NIS2/CRA PER PMI E MSP ITALIANI

Dove sei oggi. Cosa ti manca. Cosa fare nei prossimi 90 giorni.

WebDeploy – Compliance gestita. Senza drama.

Tempo di lettura: 25 minuti · **Edizione:** 2026 **A chi si rivolge:** PMI da 50 a 500 dipendenti, MSP e fornitori di servizi ICT – anche sotto soglia: i requisiti arrivano comunque, via contratto, dai clienti NIS2 – e chi in azienda risponde della sicurezza: direzione, IT, compliance/DPO. **Cosa non è:** consulenza legale. È una mappa operativa: ti dice dove guardare e cosa preparare.

In accordo alla normativa vigente WEBDEPLOY SRL distribuisce questo documento a scopo informativo: non costituisce consulenza legale né certificazione di conformità. È consentita la condivisione integrale del documento; ne è vietata la modifica o la riproduzione parziale senza autorizzazione di WEBDEPLOY SRL.

> PERCHÉ ADESSO

NIS2 non è una scadenza in arrivo: è già legge, e il calendario corre. Il **D.Lgs. 138/2024**, che recepisce la Direttiva (UE) 2022/2555, è in vigore **dal 16 ottobre 2024**; l'ACN ha già chiuso il primo censimento dei soggetti in ambito (febbraio 2025), notificato gli inserimenti nell'elenco NIS (aprile 2025) e reso vincolante la **notifica degli incidenti da gennaio 2026**. La prossima scadenza è la più impegnativa: le **misure di sicurezza di base vanno attuate entro ottobre 2026** – poi possono partire le ispezioni. Il **Cyber Resilience Act (CRA)** – Regolamento (UE) 2024/2847 – è già in vigore (dal 10 dicembre 2024): gli obblighi di **segnalazione** delle vulnerabilità attivamente sfruttate (Art. 14) **si applicano dall'11 settembre 2026**, ormai alle porte, e il regolamento **si applica in pieno dall'11 dicembre 2027**.

La maggior parte delle aziende scopre di essere "in ambito" quando arriva la prima richiesta di evidenze – da un cliente, da un auditor o dopo un incidente. A quel punto la domanda non è più *«abbiamo una policy?»*, ma *«riusciamo a dimostrarlo?»*.

> COSA TROVI IN QUESTA GUIDA

1. **Dove sei oggi.** Chi rientra nell'ambito NIS2 e chi è "fabbricante" ai sensi del CRA, senza zone grigie inutili.
2. **Cosa ti manca.** La checklist delle misure dell'**Art. 21(2)(a-j)** con lo stato tipico di una PMI e, per MSP e fornitori digitali, il rimando al Regolamento di esecuzione (UE) 2024/2690, che definisce quando un incidente è "significativo".
3. **Cosa fare nei prossimi 90 giorni.** Un piano in passi concreti, ordinati per priorità e per rischio.
4. **Se sei un fornitore.** Il questionario che ti manderà un cliente NIS2, l'evidence pack minimo con cui rispondere, cosa firmare con attenzione – e una pagina pronta da portare in CdA.

> UN'IDEA DA PORTARE CON TE

In ogni pagina torna la stessa distinzione: **controllo ≠ evidenza ≠ documento**. Il controllo è il fatto tecnico (esempio: MFA attiva). L'evidenza è la prova che funziona – il log, l'output di un check automatico. Il documento è la policy che lo richiede. Le sanzioni – **fino a 7.000.000 € o l'1,4% del fatturato annuo** per i soggetti "importanti", con l'organo di gestione che ne risponde ai sensi dell'**Art. 20** – non arrivano sulle intenzioni. Arrivano quando l'evidenza non c'è.

Niente tecnicismi superflui, niente buzzword. Venticinque minuti, e sai da dove partire.

Questo documento supporta la conformità: non è una certificazione né una consulenza legale. Le determinazioni di ambito – settore, classe del soggetto, soglie applicabili –

vanno confermate con chi ne risponde in azienda.

WebDeploy – *Compliance gestita. Senza drama.*

> NIS2 IN BREVE PER PMI E MSP

NIS2 (Direttiva (UE) 2022/2555) non è un adempimento formale in più: è un regime di gestione del rischio cyber con responsabilità che salgono fino all'organo di gestione e sanzioni misurate in milioni. In Italia è già legge – e si applica. Ecco cosa conta davvero se sei una PMI o un MSP.

> CHI RIENTRA: SOGGETTI ESSENZIALI E IMPORTANTI

L'ambito soggettivo si decide su due assi: **settore** e **dimensione**.

- **Settore.** Rientrano le entità che operano nei settori elencati negli Allegati alla direttiva – tra cui energia, trasporti, banche, sanità, acqua, pubblica amministrazione, infrastrutture digitali e, esplicitamente, i **fornitori di servizi gestiti (MSP) e di servizi di sicurezza gestiti (MSSP)**, i data center, i cloud provider e le piattaforme online.
- **Dimensione.** Di regola sono coinvolte le imprese **medie e grandi**: indicativamente da **50 dipendenti** in su, oppure con **fatturato annuo e totale di bilancio entrambi superiori a 10 milioni di euro** (soglie della Raccomandazione UE 2003/361: nel calcolo contano, di norma, anche le imprese associate e collegate). Alcune categorie rientrano **a prescindere dalla dimensione** (per esempio registri TLD, fornitori di servizi DNS, alcuni provider di comunicazioni elettroniche e servizi fiduciari).

La direttiva distingue due classi:

- **Soggetti essenziali** – vigilanza proattiva (controlli anche in assenza di incidente) e massimali sanzionatori più alti.
- **Soggetti importanti** – vigilanza a posteriori (su segnalazione o a seguito di un incidente). Un MSP di medie dimensioni, per esempio, rientra di regola come **soggetto importante**; oltre le soglie delle grandi imprese scatta, di norma, la classe **essenziale**.

La differenza principale non è **se** i requisiti si applicano – le misure dell'Art. 21 valgono per entrambe le classi – ma **quanto** è intensa la vigilanza e **quanto** pesano le sanzioni.

// L'EFFETTO SUPPLY-CHAIN: TI RIGUARDA ANCHE SE NON SEI "IN ELENCO"

Qui sta il punto per la maggior parte delle PMI e degli MSP. L'**Art. 21(2)(d)** impone ai soggetti in ambito di gestire la **sicurezza della catena di approvvigionamento**, inclusi i rapporti con i fornitori diretti. In pratica: il tuo cliente in scope NIS2 deve dimostrare di controllare i propri fornitori – e ti gira i requisiti **per contratto**: clausole di sicurezza, evidenze, diritto di audit, tempi di notifica degli incidenti.

Risultato: non serve essere formalmente "soggetto NIS2" per doverne rispettare le misure. Basta essere il fornitore di chi lo è. Per un MSP italiano questo è, di fatto, un requisito commerciale.

> ART. 20 - LA RESPONSABILITÀ SALE AL VERTICE

NIS2 sposta la cybersecurity dal reparto IT alla **sala del consiglio**. L'Art. 20 stabilisce che l'**organo di gestione** (CdA, amministratore, direzione):

- **approva** le misure di gestione del rischio cyber;
- **supervisiona** la loro attuazione;
- **risponde** delle violazioni.

È una responsabilità **non delegabile**. In più, gli stessi organi di gestione devono seguire una **formazione** adeguata a riconoscere e valutare i rischi – formazione estesa, in modo proporzionato, anche al personale. Tradotto: un consigliere deve poter dire **cosa** è stato approvato, **perché** e **come** è verificato, senza essere un tecnico.

> ART. 21 - LE MISURE MINIME DI GESTIONE DEL RISCHIO

L'Art. 21 chiede un approccio "**all-hazards**" e **proporzionato** (dimensione, esposizione al rischio, costi). Il comma 2 elenca dieci misure minime, lettere **(a)-(j)**:

- **(a)** politiche di analisi dei rischi e di sicurezza dei sistemi informativi;
- **(b)** gestione degli incidenti;
- **(c)** continuità operativa: backup, disaster recovery e gestione delle crisi;
- **(d)** sicurezza della catena di approvvigionamento;
- **(e)** sicurezza in acquisizione, sviluppo e manutenzione, con gestione e divulgazione delle vulnerabilità;
- **(f)** politiche per **valutare l'efficacia** delle misure adottate;
- **(g)** igiene informatica di base e formazione;
- **(h)** crittografia e cifratura;
- **(i)** sicurezza del personale, controllo degli accessi e gestione degli asset;
- **(j)** autenticazione a più fattori (MFA) e comunicazioni sicure.

Nota pratica: la sanzione non arriva sulla **policy**, ma sull'assenza di **evidenza** che il controllo esista e funzioni. Per alcuni fornitori digitali (cloud, data center, MSP, marketplace) il **Regolamento di esecuzione (UE) 2024/2690** dettaglia ulteriormente queste misure e definisce cosa è "incidente significativo".

> RECEPIMENTO IN ITALIA E DECORRENZA

- La **Direttiva NIS2 si applica nell'UE dal 18 ottobre 2024**. In Italia è recepita dal **D.Lgs. 138/2024**, in vigore dal **16 ottobre 2024**.
- **Autorità competente: ACN** (Agenzia per la Cybersicurezza Nazionale), che è anche **punto di contatto unico** e ospita il **CSIRT Italia** per le notifiche di incidente.
- La **registrazione sulla piattaforma ACN** non è un adempimento futuro: la prima finestra si è chiusa il **28 febbraio 2025** (17 gennaio 2025 per MSP, MSSP, cloud, data center e altri fornitori digitali) e va aggiornata ogni anno tra il 1° gennaio e il 28

febbraio. Chi era in ambito e non si è registrato è già esposto a sanzione (fino allo 0,1% del fatturato).

- Per i soggetti inseriti nell'elenco NIS (comunicazioni ACN di aprile 2025), l'**obbligo di notifica degli incidenti è operativo da gennaio 2026**; le **misure di sicurezza di base vanno attuate entro ottobre 2026**, secondo le determinazioni ACN.
- **Sanzioni** – fino a **10.000.000 € o il 2%** del fatturato annuo mondiale (essenziali), fino a **7.000.000 € o l'1,4%** (importanti): il dettaglio nella sezione «Sanzioni & responsabilità».

Le notifiche degli **incidenti significativi** – quelli che causano o possono causare grave perturbazione operativa, perdite finanziarie o danni ad altri soggetti (Art. 25 del D.Lgs. 138/2024); non ogni singolo evento – seguono poi la scaletta dell'**Art. 23** della direttiva (allerta iniziale entro 24h, notifica entro 72h, relazione finale entro un mese), trattata nella sezione dedicata.

In una riga: se operi – o fornisci – in un settore in ambito, NIS2 ti chiede misure verificabili (Art. 21), responsabilità al vertice (Art. 20) ed evidenze pronte per un audit ACN. Non documenti: evidenze.

> CRA IN BREVE

Non immetti prodotti digitali sul mercato a tuo marchio – niente app, firmware o software venduti come tuoi? Questa sezione ti serve solo per sapere cosa chiedere ai tuoi fornitori: puoi saltare al capitolo successivo.

Il **Cyber Resilience Act** – Regolamento (UE) 2024/2847 – è il primo obbligo di legge europeo che impone requisiti di cybersecurity ai **prodotti con elementi digitali**: qualunque software o hardware, e le sue soluzioni di elaborazione dati da remoto, immesso sul mercato UE. App mobili, firmware IoT, plugin, gestionali distribuiti: se contiene codice ed è immesso sul mercato UE può rientrare – salvo le esclusioni (SaaS/cloud puri, che ricadono in NIS2; software libero non commerciale; prodotti già coperti da normative settoriali come dispositivi medici, automotive, aviazione).

// CHI È "MANUFACTURER" (E PERCHÉ TOCCA ANCHE CHI RIVENDE)

Non riguarda solo i grandi vendor. È **manufacturer** chiunque sviluppi un prodotto con elementi digitali – o lo faccia sviluppare – e lo immetta sul mercato **con il proprio marchio** (Art. 3). Ma anche **importatori e distributori** hanno obblighi propri (Art. 19–20): verificare la marcatura CE, la documentazione tecnica, e non mettere in commercio prodotti non conformi. In pratica: se immetti software sul mercato UE a tuo nome o con il tuo marchio – che tu l'abbia sviluppato in casa o lo rivenda come tuo – sei manufacturer. Se invece sviluppi su commessa e il prodotto esce col marchio del cliente, il manufacturer è il cliente: ma i requisiti CRA arriveranno anche a te, per contratto.

// GLI OBBLIGHI ESSENZIALI (ALLEGATO I)

- Nessuna vulnerabilità nota sfruttabile al momento dell'immissione sul mercato
- Configurazione sicura di default e superficie d'attacco ridotta al minimo
- Autenticazione e controllo degli accessi; riservatezza e integrità dei dati
- **Processo di gestione delle vulnerabilità**: SBOM (distinta dei componenti software), disclosure coordinata e aggiornamenti di sicurezza **gratuiti** per l'intero periodo di supporto dichiarato

// ART. 14 – SEGNALARE ENTRO FINESTRE PRECISE

Dall'**11 settembre 2026**, il manufacturer deve notificare **contemporaneamente a ENISA e al CSIRT** designato come coordinatore:

- **Vulnerabilità attivamente sfruttata** – allerta entro **24h** → notifica entro **72h** → report finale entro **14 giorni** dalla misura correttiva
- **Incidente grave** che impatta la sicurezza del prodotto – allerta entro **24h** → notifica entro **72h** → report finale entro **1 mese**

24 ore non sono 24 ore di calendario: sono 24 ore di team che corre. Senza evidenze già pronte – log, timestamp, hash – la finestra si chiude prima ancora di aver capito cosa è successo.

// **TIMELINE DI APPLICAZIONE**

Data	Cosa si applica
10 dic 2024	Entrata in vigore del Regolamento (UE) 2024/2847
11 giu 2026	Capo IV – organismi di valutazione della conformità (Art. 35-51)
11 set 2026	Art. 14 – obblighi di segnalazione
11 dic 2027	Piena applicazione: marcatura CE cyber obbligatoria per l'immissione sul mercato

La conformità CRA non si compra: si costruisce, con processo ed evidenze. Così, quando la finestra delle 24h si apre, il draft di notifica è già pronto invece di essere da scrivere.

> IL CONCETTO CHIAVE: CONTROLLO ≠ EVIDENZA ≠ DOCUMENTO

Avere una misura di sicurezza non è la stessa cosa che poterla dimostrare. In un audit ACN – e nel calcolo di una sanzione – non bastano il controllo che hai attivo oggi e la policy nel cassetto: serve anche l'evidenza – la prova tracciabile che quel controllo esisteva e funzionava anche ieri, tre mesi fa, alle due di notte.

Sono tre cose distinte. La maggior parte delle PMI le confonde, e scopre la differenza solo quando arriva la richiesta di evidenze.

	Cos'è	Esempio
Controllo	Il fatto tecnico: la misura effettivamente in funzione	MFA sull'accesso SSH, richiesto dall'Art. 21(2)(j)
Documento	La policy organizzativa che prescrive quel controllo	Procedura di access management ex Art. 21(2)(i)
Evidenza	La prova verificabile e conservata che il controllo è esistito e ha funzionato nel tempo	auth.log centralizzato, con timestamp, hash e retention

L'Art. 21 NIS2 chiede le misure (i controlli) e le procedure (i documenti). Ma è l'ispezione di ACN – e la notifica di un incidente entro 24 ore, 72 ore, un mese ex Art. 23 – a giocare tutto sull'evidenza. E la sanzione arriva proprio quando l'evidenza non c'è. Non a caso l'Art. 20 mette la responsabilità in capo all'organo di gestione: non basta approvare le misure, bisogna poterle dimostrare l'attuazione.

// UN ESEMPIO CONCRETO: IL TUO AUTH.LOG

Prendi l'accesso ai server, uno dei primi punti che un auditor verifica.

- **Il controllo c'è:** SSH con MFA, accesso a chiave, blocco dei tentativi ripetuti.
- **Il documento c'è:** una policy che prescrive tutto questo.
- **L'evidenza?** Il tuo auth.log registra ogni login, ogni tentativo fallito, ogni sudo. Ma se quel file vive solo sul server, ruota dopo pochi giorni e chiunque abbia i privilegi di root può riscriverlo, in audit non vale nulla.

Quel log diventa evidenza solo quando è centralizzato fuori dal server che lo produce (così chi vi accede non può cancellarlo), conservato con una retention dichiarata, marcato con timestamp e reso verificabile nell'integrità tramite hash. Solo allora puoi rispondere alla domanda che l'auditor fa davvero:

«Dimostrami che il 3 marzo, alle 02:14, quel tentativo di accesso è stato bloccato – e che il log non è stato ritoccato dopo.»

La policy nel cassetto non risponde. Il controllo attivo oggi non risponde. Risponde solo la traccia storica, firmata e conservata.

// L'ANGOLO WEBDEPLOY

Qui sta la differenza tra avere una misura e poterla dimostrare. La nostra pipeline di managed hosting raccoglie le evidenze in automatico – auth.log e metriche via Grafana Alloy, centralizzazione e retention firmata via Loki – e le mappa direttamente ai

controlli dell'Art. 21(2)(a-j) e alle soglie dell'Implementing Reg. (EU) 2024/2690. Il risultato è un evidence pack schema-validato (`compliance-report.schema.json`), non un documento riscritto a mano il giorno prima dell'ispezione. L'evidenza si genera mentre lavori, non quando bussava l'auditor.

> SELF-ASSESSMENT NIS2/CRA: DOVE SEI OGGI

Dodici domande per capire, in dieci minuti, quanto sei distante da NIS2 e CRA – senza consulenti e senza giri di parole. Rispondi con onestà: qui non ti valuta nessuno, e un "No" sincero oggi vale più di un "Sì" che non regge in audit. Ogni riga è ancorata a una lettera precisa dell'Art. 21(2) della Direttiva (UE) 2022/2555 (NIS2) – recepito in Italia dall'art. 24, comma 2, del D.Lgs. 138/2024. Non è un audit formale né una consulenza legale: è la mappa di dove partire.

Come rispondere – un solo segno per riga:

- **Si** = la misura è attiva, documentata e produce un'evidenza verificabile (non basta "lo facciamo").
- **Parziale** = esiste, ma è incompleta, non documentata o senza evidenza tracciabile.
- **No** = assente, o non sai rispondere.

#	Ambito · Articolo	Dove sei oggi?	Si	Parziale	No
1	Policy e analisi del rischio · 21(2)(a)	Esiste una policy di sicurezza approvata e un'analisi del rischio aggiornata negli ultimi 12 mesi?	☐	☐	☐
2	Gestione degli incidenti · 21(2)(b), 23	Hai una procedura scritta di rilevamento, risposta e notifica, con ruoli e tempi (allerta 24h, notifica 72h, relazione finale 1 mese)?	☐	☐	☐
3	Backup e ripristino · 21(2)(c)	I backup sono automatici, cifrati, off-site e con un ripristino realmente testato negli ultimi 6 mesi?	☐	☐	☐
4	Continuità e gestione delle crisi · 21(2)(c)	Esiste un piano di continuità/disaster recovery con RTO e RPO definiti e un referente di crisi nominato?	☐	☐	☐
5	Catena di fornitura · 21(2)(d)	Hai un inventario dei fornitori critici e clausole di sicurezza e notifica incidenti nei contratti?	☐	☐	☐
6	Gestione delle vulnerabilità · 21(2)(e)	Fai scansioni e patch management regolari e sai in quanto tempo applichi una patch critica?	☐	☐	☐
7	Formazione e igiene informatica · 21(2)(g)	Il personale – organo di gestione incluso – ha svolto formazione su phishing e igiene informatica negli ultimi 12 mesi?	☐	☐	☐
8	Crittografia e cifratura · 21(2)(h)	Dati sensibili e canali sono cifrati (TLS, dischi, backup) secondo una policy sull'uso della crittografia?	☐	☐	☐
9	Controllo accessi e asset · 21(2)(i)	Applichi il privilegio minimo, la revoca tempestiva degli accessi e mantieni un inventario asset aggiornato?	☐	☐	☐
10	Autenticazione a più fattori · 21(2)(j)	L'MFA è attiva su tutti gli accessi amministrativi, VPN, email e sistemi critici?	☐	☐	☐
11	Log, evidenze ed efficacia · 21(2)(f)	I log (accessi, <code>auth.log</code> , modifiche) sono centralizzati, con retention definita, e producono evidenze verificabili dell'efficacia delle misure?	☐	☐	☐
12	Reporting vulnerabilità CRA · CRA Art. 14	Se pubblici prodotti con elementi digitali (app, IoT, plugin), sai notificare una vulnerabilità attivamente sfruttata entro 24h a ENISA/CSIRT (obbligo dall'11 settembre 2026)?	☐	☐	☐

// COSA SERVE PER UN "SÌ" DIFENDIBILE

In un controllo ACN non conta la buona volontà: conta l'evidenza. Per ogni riga, questo è il minimo che deve esistere e che qualcuno possa mostrare.

1. Documento di policy firmato + registro dei rischi datato.
2. Runbook incidenti + registro degli incidenti con timestamp.
3. Log dei job di backup + report dell'ultimo restore-test.
4. Piano BCP/DR con RTO/RPO + verbale dell'ultimo test.
5. Elenco fornitori critici + estratto delle clausole contrattuali.
6. Report delle scansioni + changelog delle patch con date.
7. Registro formazione + esito dell'ultima simulazione di phishing.

8. Configurazioni TLS/at-rest + policy sull'uso della crittografia.
9. Matrice ruoli/accessi + log delle revoche + inventario asset.
0. Configurazione o screenshot dell'enforcement MFA, per ciascun sistema.
1. `auth.log` centralizzato (es. Loki) con retention firmata + report periodico.
2. Procedura di notifica CRA + canale ENISA/CSIRT identificato + SBOM del prodotto.

// COME LEGGERE IL RISULTATO

Conta i "Si".

- **0-4 Si** – parti dalle fondamenta: incidenti, backup, MFA e log. Oggi sei esposto sul piano tecnico e su quello delle responsabilità: l'organo di gestione risponde **personalmente** delle misure (Art. 20).
- **5-8 Si** – hai i controlli, ma quasi certamente ti mancano le evidenze. È lo scenario più comune tra le PMI italiane, e in audit è l'evidenza – non il controllo – a fare la differenza.
- **9-12 Si** – buona base. Verifica che ogni "Si" regga con un'evidenza verificabile e aggiornata, non con una policy scritta e mai riletta.

Promemoria. L'organo di gestione risponde in prima persona delle misure (**Art. 20**): i massimali sanzionatori sono nella prossima sezione. Le misure di dettaglio per i soggetti in perimetro seguono l'Art. 21 NIS2 e, per alcune categorie – servizi gestiti/MSP inclusi – le soglie tecniche del Regolamento di esecuzione (UE) 2024/2690.

Il prossimo passo. Se più di metà delle righe è "Parziale" o "No", nella maggior parte dei casi il problema non è la tecnologia: è l'evidenza. È esattamente ciò che automatizziamo per i clienti in hosting gestito – report NIS2 firmati, evidenze raccolte dai log, mappatura diretta all'Art. 21(2)(a-j).

👉 **Iscriviti all'early access** → webdeploy.it/early-access

Compliance gestita. Senza drama.

> SANZIONI & RESPONSABILITÀ

Con NIS2 la conformità cyber smette di essere una questione tecnica e diventa una responsabilità di bilancio e di consiglio. Non è uno scenario teorico: la Direttiva (UE) 2022/2555 è recepita in Italia dal **D.Lgs. 138/2024**, in vigore dal **16 ottobre 2024**.

L'autorità competente – l'**Agenzia per la Cybersicurezza Nazionale (ACN)** – ha già censito i soggetti in scope (prima finestra di registrazione chiusa a febbraio 2025), comunicato gli inserimenti nell'elenco NIS e reso operativo l'obbligo di notifica degli incidenti dal 1° gennaio 2026. La prossima scadenza – le misure di sicurezza di base – è a **ottobre 2026**.

// I TETTI SANZIONATORI

Le sanzioni amministrative pecuniarie sono calibrate sulla classificazione del soggetto. Si applica sempre **l'importo più elevato** tra il valore fisso e la percentuale del fatturato.

Soggetto	Sanzione massima	oppure
Essenziale	fino a 10.000.000 €	2% del fatturato annuo mondiale totale
Importante	fino a 7.000.000 €	1,4% del fatturato annuo mondiale totale

(Rif. Art. 34 NIS2, recepito dal D.Lgs. 138/2024.) Il fatturato di riferimento è quello dell'esercizio precedente, su scala mondiale e riferito all'intero gruppo di appartenenza – non alla sola unità interessata.

// LA RESPONSABILITÀ È PERSONALE, ED È FORMATIVA

L'**Art. 20** attribuisce l'obbligo direttamente all'**organo di gestione** (CdA, amministratori, direzione). Non è delegabile all'IT. In concreto, l'organo di gestione deve:

- **approvare** le misure di gestione del rischio adottate ex Art. 21;
- **supervisionarne** l'attuazione;
- **rispondere** delle violazioni – una responsabilità che ricade sui membri dell'organo, non solo sulla società;
- **formarsi**: la direttiva impone ai membri dell'organo di gestione di seguire una formazione adeguata per identificare i rischi e valutare le pratiche di sicurezza.

Per i soggetti essenziali, le autorità possono spingersi fino alla sospensione temporanea di funzioni dirigenziali in capo alla persona fisica. Il messaggio del legislatore è netto: chi decide, risponde.

// IL COSTO CHE NON È IN TABELLA

La sanzione dell'autorità è solo una parte del rischio.

- **Reputazione**. Un incidente notificato e un'eventuale misura dell'ACN sono fatti pubblici. La fiducia persa vale spesso più della multa.
- **Verso i clienti**. NIS2 impone di valutare la sicurezza della catena di fornitura (Art. 21). Un cliente in scope ti chiederà le **evidenze** – log, report, audit trail. Chi non

le ha pronte non prende una multa: perde il contratto, a favore di un fornitore che le ha.

È qui che la compliance smette di essere un costo difensivo e diventa un requisito commerciale. Averla *gestita* – con evidenze pronte, non con una policy chiusa in un cassetto – è ciò che tiene in piedi il rapporto con i clienti che, a loro volta, devono rispondere ad ACN.

> TI È ARRIVATO UN QUESTIONARIO DA UN CLIENTE NIS2?

Se sei un fornitore – MSP, software house, servizi ICT, ma anche componentistica per un gruppo industriale in ambito – prima o poi arriva: una PEC con un questionario di sicurezza, un allegato contrattuale nuovo, una richiesta di «evidenze di conformità cyber». Non è burocrazia del cliente: è l'**Art. 21(2)(d)** che gli impone di controllare i fornitori – e di dimostrarlo ad ACN. Ignorare la richiesta significa uscire dalla lista fornitori alla prossima gara.

// LE DOMANDE CHE TI FARANNO (QUASI) SICURAMENTE

1. **MFA** – è attiva sugli accessi amministrativi e remoti?
2. **Backup** – con quale frequenza, dove, e quando hai testato l'ultimo ripristino?
3. **Patch** – in quanto tempo applichi una correzione critica?
4. **Incidenti** – in quanto tempo ci avvisi se hai un incidente che ci tocca?
5. **Log ed evidenze** – conservate traccia degli accessi ai sistemi? Dove, e per quanto tempo? Potete fornirne un estratto su richiesta?
6. **Certificazioni** – hai ISO 27001 o simili? (Non sempre è un requisito rigido – vedi sotto.)
7. **Subfornitori e dati** – quali cloud e subfornitori usi per erogare il nostro servizio, e dove risiedono i dati?
8. **Incidenti pregressi** – hai subito incidenti o data breach negli ultimi 24 mesi? Come li hai gestiti?
9. **Assicurazione cyber** – hai una polizza attiva, e con quali massimali?

Nella pratica spesso non sono nove domande: è un foglio Excel da 80-200 righe mappato su ISO 27001 o sulle misure ACN, da restituire compilato in un paio di settimane. La mossa che ripaga è costruire **una volta sola** un archivio di risposte standard – ogni risposta agganciata alla lettera dell'Art. 21(2) e all'evidenza corrispondente – così ogni nuovo questionario diventa compilazione, non progetto.

// L'EVIDENCE PACK MINIMO – IN PRATICA, UNA CARTELLA DI PROVE

Prepara una cartella, aggiornala ogni trimestre, e rispondi **allegando** – non raccontando:

- configurazione o export che dimostri che l'**autenticazione a più fattori (MFA)** è obbligatoria – non solo disponibile – sui sistemi con cui lavori per quel cliente (posta, gestionale, accessi remoti): l'output datato di un check automatico vale più di uno screenshot;
- **report dell'ultimo test di ripristino** dei backup, con data;
- **elenco degli aggiornamenti di sicurezza applicati** negli ultimi 3 mesi, con le date (o il report delle scansioni);
- la tua **procedura di notifica incidenti**, con i tempi che garantisci;
- un **estratto dei log degli accessi** ai sistemi usati per quel cliente, indicando dove sono conservati e per quanto tempo. Non li hai centralizzati? Scrivilo, e metti la centralizzazione nel piano a 90 giorni: una risposta onesta con una data regge meglio di una promessa.

// COSA FIRMARE CON ATTENZIONE

- **Diritto di audit** – richiesta legittima, ma negozia preavviso, perimetro (i sistemi che servono quel cliente, non tutta l'azienda) e frequenza.
- **Tempi di notifica incidenti** – prometti quello che sai mantenere, ricordando che il tuo cliente NIS2 ha a sua volta **24 ore** dalla conoscenza dell'incidente per la pre-allerta al CSIRT Italia: difficilmente accetterà decorrenze dalla «conferma dell'impatto». Un impegno a due livelli – *avviso preliminare entro 24h dalla scoperta, anche con informazioni incomplete; dettaglio entro 72h* – è sostenibile; «entro 2 ore dall'evento» no. Prima di firmare, fai verificare i tempi al tuo legale.
- **Richieste di certificazione sproporzionate** – se non hai la ISO 27001, proponi evidenze alternative: report periodici firmati, test di ripristino, log verificabili. Non equivalgono a una certificazione di terza parte, ma molti clienti le accettano: ciò che vogliono davvero è coprire il *loro* audit. Occhio però: in gare pubbliche e con clienti bancari o sanitari la ISO può essere un requisito escludente – se te la chiedono spesso, mettila a piano.

In tre mosse: rispondi subito alla PEC indicando i tempi; compila con onestà (un «Parziale» con un piano a 90 giorni vale più di un «Sì» che crolla in audit); allega l'evidence pack. Il fornitore che risponde con evidenze non perde il contratto – di solito ne vince altri.

> IL PIANO DEI 90 GIORNI: DA ZERO AD AUDIT-READY

NIS2 è legge in Italia dal **16 ottobre 2024** (D.Lgs. 138/2024) – e la prima scadenza operativa è vicina: per i soggetti già inseriti nell'elenco ACN, le misure di sicurezza di base vanno attuate **entro ottobre 2026**. Le sanzioni colpiscono le **evidenze**, non le buone intenzioni. E per l'organo di gestione la responsabilità è personale e non delegabile (**Art. 20**).

La buona notizia: non serve un progetto da un anno. Servono tre sprint da 30 giorni, ciascuno chiuso da un output verificabile. Questa è la roadmap che usiamo con i nostri clienti managed.

Legenda «Chi»: **Sponsor** = organo di gestione / titolare (Art. 20) · **IT** = CTO / IT manager · **Compliance** = DPO / compliance officer · **MSP** = fornitore di hosting gestito (WebDeploy o equivalente).

// SPRINT 1 · GIORNI 0-30 – ASSESSMENT E QUICK WIN

Obiettivo. Sapere dove sei e chiudere subito le lacune a costo zero o quasi. In 30 giorni non si «diventa conformi»: si smette di essere ciechi.

Cosa fai:

- **Perimetro e scope.** Elenca sistemi, servizi digitali e dati in ambito; verifica se sei soggetto «essenziale» o «importante» e nomina lo sponsor in CdA (Art. 20).
- **Gap assessment** sui dieci punti dell'**Art. 21(2)(a-j)**: per ciascuno, controllo sì/no ed evidenza sì/no.
- **Quick win ad alto impatto:**
 - **MFA** su accessi privilegiati, VPN, pannelli admin e posta – Art. 21(2)(j).
 - **Backup con restore test** documentato: il backup che non hai mai ripristinato non è un backup – Art. 21(2)(c).
 - **Centralizzazione dei log** di autenticazione (`auth.log`, accessi ai pannelli): senza log conservati non esiste evidenza.

Output. Registro dell'ambito NIS2; matrice gap Art. 21(2)(a-j) con priorità; MFA attiva sui sistemi critici; report di restore test firmato; log di autenticazione centralizzati con retention definita.

Chi. Sponsor (mandato + budget) · IT (esecuzione tecnica) · Compliance (matrice gap) · MSP (log centralizzati e MFA lato hosting).

// SPRINT 2 · GIORNI 30-60 – PROCESSI INCIDENTI, SUPPLY CHAIN, POLICY

Obiettivo. Passare dai controlli tecnici ai processi ripetibili e scritti – quelli che un auditor ACN chiede di vedere **in azione**, non solo su carta.

Cosa fai:

- **Gestione incidenti** – Art. 21(2)(b) + Art. 23. Definisci ruoli, canali e tempistiche: NIS2 impone allerta iniziale entro **24h**, notifica entro **72h**, report finale entro **1**

mese. Se pubblici software o app, aggiungi il flusso **CRA Art. 14** verso ENISA/CSIRT (early warning 24h, notifica 72h; report finale: 14 giorni dalla misura correttiva per le vulnerabilità attivamente sfruttate, 1 mese per gli incidenti gravi). Chiudi lo sprint con un *tabletop test*.

- **Supply chain** – Art. 21(2)(d). Censisci i fornitori critici (hosting, SaaS, sviluppatori), inserisci clausole di sicurezza contrattuali e, per ciascuno, richiedi l'evidenza (report, certificazioni, SBOM dove applicabile).
- **Policy essenziali, brevi e reali** – Art. 21(2)(e, f, i). Gestione vulnerabilità e disclosure, controllo accessi, cifratura, uso accettabile. Poche pagine ciascuna, datate e approvate dallo sponsor.

Output. Procedura di incident response con tempistiche 24/72h documentata e testata; registro fornitori critici con clausole ed evidenze; set di policy approvate e datate; piano di gestione delle vulnerabilità.

Chi. Compliance (policy, registro fornitori) · IT (procedura tecnica, tabletop) · Sponsor (approvazione formale) · MSP (evidenze lato infrastruttura, SBOM dei componenti gestiti).

// SPRINT 3 · GIORNI 60-90 – AUTOMAZIONE EVIDENZE, REPORTING, AUDIT-READY

Obiettivo. Rendere l'evidenza *continua*, non un file raccolto a mano il giorno prima dell'audit. Uscire dallo sprint con un fascicolo che regge una richiesta ACN.

Cosa fai:

- **Automatizza la raccolta evidenze.** Una pipeline genera un report periodico schema-validato – nel nostro stack: Grafana Alloy → Loki → report JSON secondo `compliance-report.schema.json` v1.0.0 – con hash dei log e timestamp verificabili.
- **Reporting mappato.** Ogni report collega evidenza ↔ controllo ↔ Art. 21(2)(a-j) ↔ soglia dell'**Implementing Reg. (EU) 2024/2690** per la significatività degli incidenti.
- **Prova d'audit (dry run).** Simula le domande dell'auditor – «mostrami che l'MFA è attiva e da quando», «dammi la timeline dell'ultimo incidente» – e verifica di poter rispondere con evidenze, non con promesse.

Output. Report di compliance automatico, firmato, in PDF + JSON; audit trail con hash e retention; fascicolo d'audit pronto (scope, policy, evidenze, incident log); calendario di revisione periodica.

Chi. IT + MSP (automazione pipeline e report) · Compliance (mappatura e fascicolo) · Sponsor (revisione trimestrale in CdA).

// DOPO I 90 GIORNI

La conformità non è un traguardo ma uno stato da mantenere: report periodici, restore test ricorrenti, revisione fornitori, aggiornamento delle policy. Lo Sprint 3 è il punto in cui un hosting gestito con compliance integrata fa la differenza – l'evidenza si genera da sola, ogni mese, senza dipendere dalla memoria di qualcuno.

Con la pipeline managed di WebDeploy, gran parte degli Sprint 1 e 3 è già pronta dal primo giorno: MFA, log centralizzati, backup verificati e report NIS2 schema-validati fanno parte dell'hosting, non di un progetto a parte.

> DA PORTARE IN CDA: LA PAGINA PER CHI DECIDE

Questa pagina è fatta per essere stampata e messa sul tavolo della prossima riunione. Cinque minuti, tre decisioni. E se il «CdA» sei tu – titolare o amministratore unico – vale lo stesso: le tre decisioni restano tue, e metterle per iscritto con data e firma è esattamente la supervisione che l'Art. 20 chiede di poter dimostrare.

Perché riguarda il consiglio, non l'IT. L'Art. 20 della NIS2 mette in capo all'organo di gestione l'**approvazione** delle misure di gestione del rischio cyber, la **supervisione** della loro attuazione e la **responsabilità** delle violazioni – personale e non delegabile, fino alla sospensione temporanea di funzioni dirigenziali per i soggetti essenziali. Gli stessi membri devono seguire una formazione adeguata a riconoscere e valutare i rischi.

I numeri, una volta sola. Per chi è in ambito NIS2: sanzioni fino a **10.000.000 € o il 2%** del fatturato annuo mondiale (soggetti essenziali), fino a **7.000.000 € o l'1,4%** (importanti) – si applica il maggiore. Mancata registrazione ACN: fino allo **0,1%**. E il costo che vale anche per chi non è in ambito: i clienti NIS2 chiedono evidenze ai fornitori **per contratto** – chi non le ha perde la gara, non prende la multa.

La scadenza. Per i soggetti inseriti nell'elenco ACN, la notifica degli incidenti è obbligatoria **da gennaio 2026** e le misure di sicurezza di base vanno attuate **entro ottobre 2026**. Se non sei in elenco, la scadenza la fissa il cliente: la data di risposta al questionario o la prossima qualifica fornitori – spesso settimane, non mesi. Deliberare a settembre non è un piano.

Le tre decisioni da mettere a verbale:

- 1. Nomina dello sponsor** – un membro dell'organo di gestione con mandato e delega di spesa (Art. 20). La nomina non esonera gli altri membri: approvazione e supervisione restano dell'organo nel suo insieme.
- 2. Budget dei primi 30 giorni (Sprint 1)** – valutazione dei gap + primi interventi (autenticazione a più fattori, test di ripristino dei backup, log raccolti in un punto centrale): in gran parte ore interne o del consulente IT già contrattualizzato – l'ordine di grandezza è quello di alcune giornate di lavoro, non di un progetto di consulenza da sei mesi.
- 3. Calendario con verifica trimestrale** – 90 giorni per essere audit-ready, poi revisione in consiglio ogni trimestre con il report evidenze sul tavolo.

La domanda da fare a chi gestisce l'IT: *«Se ACN ce lo chiedesse domani, sappiamo dimostrare – non raccontare – che le misure approvate funzionano?»* Se la risposta esita, il punto va a verbale.

> COME WEBDEPLOY TI AIUTA

Il gap che hai appena mappato – i controlli dell'Art. 21(2)(a-j), le soglie dell'Implementing Reg. (EU) 2024/2690, le voci da chiudere nei prossimi 90 giorni – è lavoro vero. WebDeploy lo chiude come **servizio gestito**, non come l'ennesima consulenza che ti lascia un PDF e una fattura: managed hosting con la compliance integrata, non come add-on.

Cosa attiviamo sui tuoi host

- **Pipeline `monitor`** – Grafana, Loki, Prometheus, Alloy e Caddy installati sui tuoi server via Ansible. Interamente open source: nessun agent proprietario, i dati restano da te.
- **Report mensile NIS2** in PDF firmato + JSON schema-valid (`compliance-report.schema.json v1.0.0`), con i controlli mappati direttamente all'Art. 21(2)(a-j). Evidenza verificabile, non solo policy.
- **Evidenze automatiche** – `auth.log` e metriche raccolti via Alloy, centralizzati su Loki con hash e timestamp. Le stesse evidenze che servono a rilevare e ricostruire un incidente – e, per i clienti che sono *fabbricanti* ai sensi del CRA, a supportare il reporting delle vulnerabilità ex Art. 14.
- **Dashboard con SSO** – le tue metriche in tempo reale, accesso con il tuo identity provider.
- **Backup e aggiornamenti gestiti** – backup cifrati dei sistemi in hosting con test di ripristino documentati, e aggiornamenti di sicurezza dell'infrastruttura gestita applicati e tracciati, con changelog datato. Sono le evidenze dietro le righe (c) ed (e) della tabella qui sotto.
- **Niente lock-in** – stack interamente open source. Se te ne vai, porti via tutto.

Cosa copre la pipeline – e cosa resta a te

Nessun fornitore può renderti conforme «chiavi in mano» – chi lo promette, sta vendendo. La divisione onesta del lavoro, lettera per lettera:

Art. 21(2)	Misura	La pipeline copre	Resta in azienda
(a)	Policy e analisi rischi	inventario host, log e metriche a supporto dell'analisi	scrittura dell'analisi e approvazione
(b)	Gestione incidenti	alerting su log e metriche, raccolta centralizzata, timeline ricostruibile	trriage, procedura, ruoli, notifica al CSIRT Italia
(c)	Backup e continuità	backup gestiti + test di ripristino documentati	piano di continuità aziendale
(d)	Supply chain	noi siamo il fornitore con evidenze pronte	censimento e clausole con tutti i fornitori (noi inclusi)
(e)	Vulnerabilità	patching dell'infrastruttura gestita	il codice delle tue applicazioni
(f)	Valutazione efficacia	report mensile firmato, schema-validato	revisione e azioni conseguenti
(g)	Formazione	–	tutta (registro + simulazioni)
(h)	Crittografia	TLS e cifratura at-rest lato hosting	dispositivi e sistemi interni
(i)	Accessi e asset	SSO, log accessi centralizzati	matrice ruoli, inventario completo
(j)	MFA	server, pannelli e dashboard gestiti	email, gestionali, sistemi interni

E per il CRA? La pipeline copre le evidenze lato hosting utili alla notifica ex Art. 14 – log, timestamp, timeline ricostruibile. I requisiti di prodotto dell'Allegato I – SBOM del tuo software, configurazione sicura di default, gestione delle vulnerabilità del codice – restano interamente al fabbricante: cioè a te.

Early access – 10 PMI italiane

Apriamo il programma a 10 aziende: pilot di 60 giorni, onboarding incluso, prezzo fondatori bloccato per tutta la durata del pilot. Cerchiamo PMI con almeno 3 server Linux e un referente tecnico interno. Tu ci dai feedback su cosa un audit chiede davvero; esci con evidenze pronte per ACN.

→ **Iscriviti all'early access** · webdeploy.it/early-access

Sei un MSP o una software house? La stessa pipeline in modalità partner: la installi e gestisci tu sui clienti in assistenza (playbook Ansible, stack open source, niente lock-in) oppure la gestiamo noi, con report a tuo marchio e perimetro di accesso definito per iscritto – sai sempre chi entra dove. E siccome diventiamo un tuo fornitore, ti consegniamo lo stesso evidence pack che i tuoi clienti chiedono a te: pronto per il tuo registro fornitori ex Art. 21(2)(d). Scrivici: info@webdeploy.it, oggetto «Partner MSP».

Compliance gestita. Senza drama.